

# SIMATS ENGINEERING

## ASSESSMENT TOOL 1- Enumeration Analysis

**COURSE CODE: ITA14 COURSE NAME: Ethical Hacking**

### COURSE OUTCOME COVERED

**CO3:** *Analyse network services using port scanning, ping sweeps, and enumeration techniques across different operating systems to identify vulnerabilities. (BL3)*

*Assessment Tool Weightage: 40%*

### QUESTIONS: 5 Total Marks:100

1. A cyber security consulting company has been contracted to perform an initial security assessment of the publicly accessible server **scanme.nmap.org**. Before conducting any vulnerability assessment, the client requires a detailed enumeration report. Using **Nmap**, perform host discovery, TCP port scanning, service version detection, operating system fingerprinting, and default script scanning on **scanme.nmap.org**. Analyze all identified ports and services, determine their business purpose, and evaluate whether they are necessary for public access. Discuss how a threat actor could utilize the information gathered during enumeration to launch further attacks such as service exploitation, brute-force attacks, or vulnerability discovery. Prepare a technical report summarizing your findings, attack surface analysis, risk assessment, and recommendations for securing the server.

#### **Nmap Commands**

- **Host discovery:** `nmap -sn scanme.nmap.org`
- **TCP port scanning:** `nmap -sT scanme.nmap.org`
- **Service version detection:** `nmap -sV scanme.nmap.org`
- **OS detection:** `sudo nmap -O scanme.nmap.org`
- **Default NSE script scanning:** `nmap -sC scanme.nmap.org`
- **Comprehensive enumeration:** `sudo nmap -sC -sV -O scanme.nmap.org`

#### **Enumeration Analysis**

The scan identifies the ports that are accessible from the public network and the services associated with those ports. Commonly observed services on this Nmap test host include:

| Port                   | Service             | Purpose                      | Risk                  |
|------------------------|---------------------|------------------------------|-----------------------|
| 22/TCP                 | SSH                 | Secure remote administration | Medium                |
| 80/TCP                 | HTTP                | Web service                  | Medium                |
| Other discovered ports | As reported by Nmap | Depends on service           | Evaluate individually |

The exact ports and versions should be taken from the Nmap output captured during the experiment. **Attack Surface Analysis**

The exposed services provide information that can be useful to an attacker during reconnaissance. For example:

- **SSH** can reveal a remote administration interface.
- **HTTP** identifies a web server and provides an entry point for web-related testing.
- **Service versions** can be compared against known vulnerabilities.
- **OS information** can help an attacker select appropriate attack techniques.
- NSE scripts can reveal additional information about supported protocols and configurations.

A threat actor could use this information for further vulnerability discovery, targeted service exploitation, password attacks against permitted authentication interfaces, or identification of outdated software.

### Security Recommendations

- Expose only services that are required.
- Keep the operating system and services updated.
- Restrict administrative services using firewall rules.
- Use strong authentication for SSH.
- Disable unnecessary accounts and services.
- Monitor authentication and network activity.
- Regularly perform vulnerability assessments.
- Avoid exposing administrative interfaces directly to the Internet where possible.

### Conclusion

Nmap enumeration provides an overview of the externally visible attack surface. The discovered services should be evaluated based on their business requirement, configuration,

2. The security team has deployed a deliberately vulnerable Linux server, **192.168.56.101 (Metasploitable 2)**, in an isolated laboratory environment to train penetration testers. As part of the pre-engagement reconnaissance phase, use **Nmap** to perform comprehensive enumeration of **192.168.56.101**. Identify all open ports, running services, service versions, and operating system information. Analyze the purpose of each service and determine which services could provide

potential entry points for an attacker. Categorize the discovered services into High, Medium, and Low risk levels based on their exposure and functionality. Explain how the enumeration results could guide a penetration tester in selecting potential attack vectors and exploitation strategies.

### Nmap Commands

- Host discovery: `nmap -sn 192.168.56.101`
- TCP port scan: `nmap -p- 192.168.56.101`
- Service detection: `nmap -sV 192.168.56.101`
- OS detection: `sudo nmap -O 192.168.56.101`
- Default scripts: `nmap -sC 192.168.56.101`
- Comprehensive scan: `sudo nmap -sC -sV -O -p- 192.168.56.101`

### Expected Enumeration

Metasploitable 2 is intentionally vulnerable and normally exposes many network services. Your Nmap output may contain services such as:

| Port        | Example Service  | Purpose                         | Risk     |
|-------------|------------------|---------------------------------|----------|
| 21          | FTP              | File transfer                   | High     |
| 22          | SSH              | Remote administration           | Medium   |
| 23          | Telnet           | Remote login                    | High     |
| 25          | SMTP             | Email service                   | Medium   |
| 53          | DNS              | Name resolution                 | Medium   |
| 80          | HTTP             | Web server                      | High     |
| 111         | RPC              | Remote procedure calls          | High     |
| 139         | NetBIOS/SMB      | File/printer sharing            | High     |
| 445         | SMB              | Windows-compatible file sharing | High     |
| 3306        | MySQL            | Database service                | High     |
| Other ports | Various services | Depends on service              | Evaluate |

**Important:** Use the ports actually displayed by your Nmap scan in your final table rather than copying this example table unchanged.

### Risk Classification

- **High Risk**

Services that provide significant attack surface or potentially allow unauthorized access include:

- FTP
- Telnet
- SMB/NetBIOS
- Exposed databases
- Vulnerable web applications
- Outdated network services
- 

- **Medium Risk**

Examples include:

- SSH
- SMTP
- DNS
- RPC services

- **Low Risk**

Services that expose limited information and are appropriately configured may be considered lower risk. However, the risk depends on the actual configuration.

## **How Enumeration Helps a Penetration Tester**

The enumeration results allow a tester to:

- Identify possible entry points.
- Determine the software and service versions.
- Search for known vulnerabilities associated with those versions.
- Identify insecure protocols such as Telnet.
- Identify exposed file-sharing services.
- Investigate web applications.
- Determine whether databases are externally accessible.
- Prioritize testing based on risk.

## **Recommendations**

- ## Conclusion

## Report:

[illegible]

```

kali@kali:~$ sudo nmap -p- -sV -O -sC 192.168.56.101
Starting Nmap 7.95 ( https://nmap.org ) at 2020-08-14 12:48 EDT
Nmap scan report for 192.168.56.101
Host is up (0.032s latency).
Not shown: 63119 filtered tcp ports (no-response), 2415 filtered tcp ports (net-unreach)
PORT      STATE SERVICE VERSION
5060/tcp  open  sip?
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: bridge/vuIP adapter/general purpose
Running (JUST GUESSING): Oracle Virtualbox (98%), Slirp (98%), AT&T embedded (95%), QEMU (94%)
OS CPE: cpe:/o:oracle:virtualbox cpe:/a:danny_gasparovski:slirp cpe:/a:qemu:qemu
Aggressive OS guesses: Oracle Virtualbox Slirp NAT bridge (98%), AT&T BOW210 voice gateway (95%), QEMU user mode ne
twork gateway (94%)
No exact OS matches for host (test conditions non-ideal).

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 499.24 seconds

```

3. A financial organization wants to assess the security posture of a Windows workstation located at **192.168.56.102** before connecting it to the production network. Using **Nmap**, enumerate **192.168.56.102** to identify active ports, network services, file-sharing protocols, remote management services, and operating system details. Analyze whether the discovered services comply with the principle of least privilege and identify any services that may unnecessarily increase the attack surface. Discuss how an attacker could leverage the identified services for reconnaissance, lateral movement, or unauthorized access. Based on your findings, propose a set of security hardening measures to improve the system's resilience against cyberattacks.

## Nmap Commands

- Host discovery: `nmap -sn 192.168.56.102`
- All TCP ports: `nmap -p- 192.168.56.102`
- Service detection: `nmap -sV 192.168.56.102`
- OS detection: `sudo nmap -O 192.168.56.102`
- Default scripts: `nmap -sC 192.168.56.102`
- Comprehensive scan: `sudo nmap -sC -sV -O -p- 192.168.56.102`

## Services to Analyze

Windows systems may expose services such as:

| Port        | Service           | Purpose                   | Security Concern              |
|-------------|-------------------|---------------------------|-------------------------------|
| 135         | MSRPC             | Windows RPC communication | Information exposure          |
| 139         | NetBIOS/SMB       | File/printer sharing      | High if unnecessary           |
| 445         | SMB               | Windows file sharing      | High                          |
| 3389        | RDP               | Remote desktop            | High if exposed unnecessarily |
| 80/443      | HTTP/HTTPS        | Web service               | Depends on application        |
| Other ports | Depends on system | Various                   | Analyze individually          |

## Least Privilege Analysis

The principle of least privilege states that only necessary services and permissions should be provided.

For example:

- If file sharing is not required, SMB should be restricted.
- If remote desktop is not required, RDP should be disabled or restricted.
- Management services should not be accessible from untrusted networks.
- Administrative interfaces should be limited to authorized administrators.

## Attack Surface

An attacker could use discovered services for:

- **Reconnaissance:** Identify Windows version, service versions, domain/workgroup information, and available network services.
- **Lateral Movement:** Compromised credentials may potentially be used against SMB or RDP services.
- **Unauthorized Access:** Weak authentication or insecure configurations could increase the possibility of unauthorized access.

## Security Hardening

- Disable unnecessary services.
- Restrict SMB access using firewall rules.
- Disable NetBIOS where it is not required.
- Restrict RDP to trusted management networks.
- Use strong passwords and account policies.
- Enable multi-factor authentication where supported.
- Keep Windows and installed applications updated.
- Enable host-based firewall protection.
- Monitor failed authentication attempts.
- Segment workstations from sensitive production systems.

## Conclusion

Nmap helps identify unnecessary network exposure before the workstation is connected to the production environment. Services that are not required should be disabled or restricted to minimize





gathered during enumeration could be used to identify potential vulnerabilities in the web application environment and recommend measures to minimize exposure

## Nmap Commands

- Host discovery: `nmap -sn 192.168.56.103`
- Port scan: `nmap -p- 192.168.56.103`
- Service detection: `nmap -sV 192.168.56.103`
- OS detection: `sudo nmap -O 192.168.56.103`
- Default scripts: `nmap -sC 192.168.56.103`
- Comprehensive scan: `sudo nmap -sC -sV -O -p- 192.168.56.103`

## Service Analysis

The main purpose of the server is to host the Juice Shop web application. Therefore, an HTTP or HTTPS service is expected depending on the laboratory configuration.

| Service                   | Purpose                  | Risk                 |
|---------------------------|--------------------------|----------------------|
| HTTP                      | Hosts web application    | High                 |
| HTTPS                     | Secure web access        | Medium/High          |
| SSH                       | Server administration    | Medium               |
| Other discovered services | Supporting functionality | Analyze individually |

## Web Application Attack Surface

The enumeration information can help a penetration tester determine:

- Which web ports are accessible.
- Which web server/application technology is being used.
- Whether additional administrative interfaces are exposed.
- Which service versions are running.
- Whether unnecessary services are available.
- Which areas require further authorized security testing.

## Risks

Exposed web services can increase the possibility of:

- Web application vulnerability discovery.
- Authentication weaknesses.
- Misconfiguration discovery.
- Information disclosure.

- Exploitation of vulnerable supporting software.

Administrative interfaces are particularly sensitive because compromise could potentially provide control over the application or server.

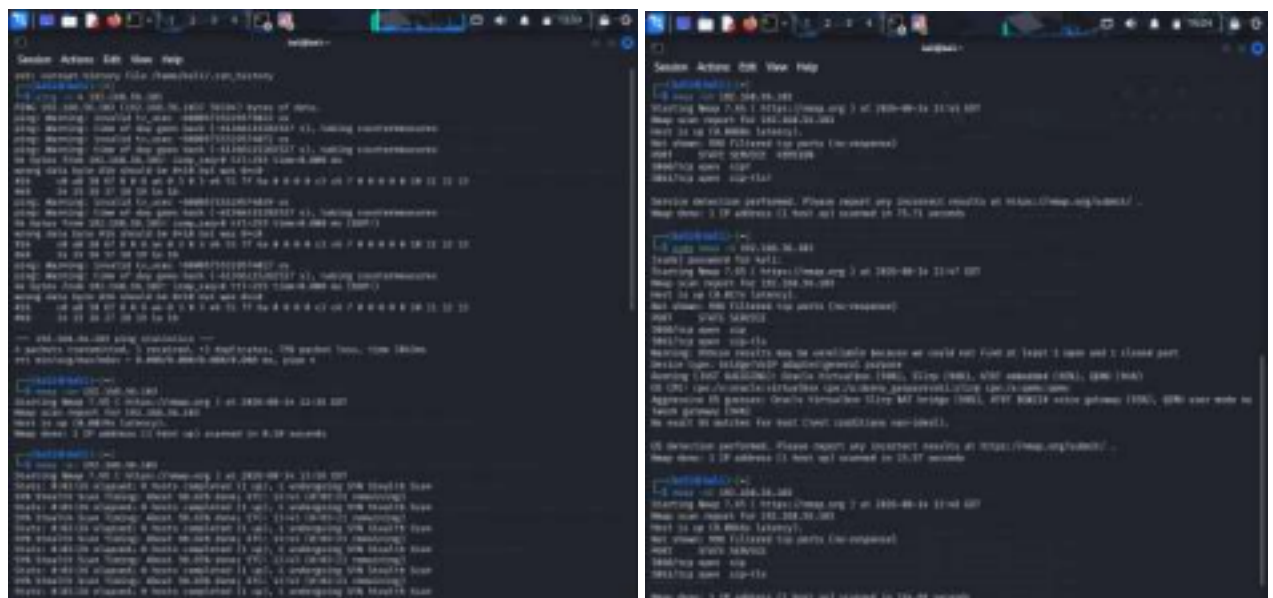
## Recommendations

- Expose only required web ports.
- Disable unnecessary administrative services.
- Restrict SSH/management access.
- Keep the server and application dependencies updated.
- Use HTTPS for production environments.
- Implement firewall rules.
- Separate the application server from sensitive internal systems.
- Monitor web and authentication logs.
- Regularly perform authorized vulnerability assessments.

## Conclusion

Nmap enumeration identifies the network-level attack surface of the Juice Shop environment. The results can be used to prioritize subsequent authorized penetration-testing activities.

Report:



```

(kali@kali)-[~]
$ sudo nmap -p- -sV -O -sC 192.168.56.103
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-14 13:51 EDT
Nmap scan report for 192.168.56.103
Host is up (0.011s latency).
Not shown: 65533 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
5060/tcp  open  sip?
5061/tcp  open  sip-tls?
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: bridge|VoIP adapter|general purpose
Running (JUST GUESSING): Oracle Virtualbox (98%), Slirp (98%), AT&T embedded (95%), QEMU (94%)
OS CPE: cpe:/o:oracle:virtualbox cpe:/a:danny_gasparovski:slirp cpe:/a:qemu:qemu
Aggressive OS guesses: Oracle Virtualbox Slirp NAT bridge (98%), AT&T BGW210 voice gateway (95%), QEMU user mode ne
twork gateway (94%)
No exact OS matches for host (test conditions non-ideal).

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 722.85 seconds

```

5. The network gateway device at **192.168.56.1** serves as the primary access point between the internal laboratory network and external networks. The network administrator suspects that unnecessary management services may be exposed. Using **Nmap**, conduct a comprehensive enumeration of **192.168.56.1**, including port scanning, service detection, operating system fingerprinting, and script based enumeration. Identify all exposed management interfaces, network services, and accessible resources. Analyze the security implications of exposing services such as SSH, Telnet, SNMP, HTTP, or HTTPS management interfaces. Discuss how attackers could exploit misconfigured management services to gain unauthorized access to the network infrastructure. Based on your analysis, recommend security controls and best practices to secure the gateway device and reduce the risk of compromise.

**Nmap Commands**

- Host discovery: `nmap -sn 192.168.56.1`
- TCP port scan: `nmap -p- 192.168.56.1`
- Service detection: `nmap -sV 192.168.56.1`
- OS fingerprinting: `sudo nmap -O 192.168.56.1`
- Default script scanning: `nmap -sC 192.168.56.1`
- Comprehensive enumeration: `sudo nmap -sC -sV -O -p- 192.168.56.1`

**Management Services to Analyze**

| Port        | Service           | Purpose                       | Security Risk        |
|-------------|-------------------|-------------------------------|----------------------|
| 22          | SSH               | Secure administration         | Medium               |
| 23          | Telnet            | Remote administration         | <b>High</b>          |
| 80          | HTTP              | Web management                | <b>High</b>          |
| 443         | HTTPS             | Secure web management         | Medium               |
| 161/UDP     | SNMP              | Network monitoring/management | Medium/High          |
| Other ports | Depends on device | Network functions             | Analyze individually |

## Security Implications

- **SSH:** It is safer than Telnet when properly configured, but exposing it unnecessarily increases the management attack surface.
- **Telnet:** It is insecure because credentials and communication can be transmitted without adequate encryption. It should normally be disabled.
- **HTTP:** Its management interface may expose administrative functionality without encryption. HTTPS should be preferred.
- **HTTPS:** It provides encrypted communication, but the management interface should still be restricted to authorized administrators.
- **SNMP:** Poorly configured SNMP can expose information about the network device and its configuration. Weak or default community strings can increase the risk.

## Attack Surface Analysis

An attacker who discovers management services may use the information to:

- Identify the gateway's operating system or firmware.
- Determine available management interfaces.
- Identify software versions.
- Discover network configuration information.
- Search for known vulnerabilities.
  - Attempt unauthorized authentication where permitted during an authorized assessment.

Compromising a gateway could have serious consequences because it may provide access to other systems on the network.

## Security Recommendations

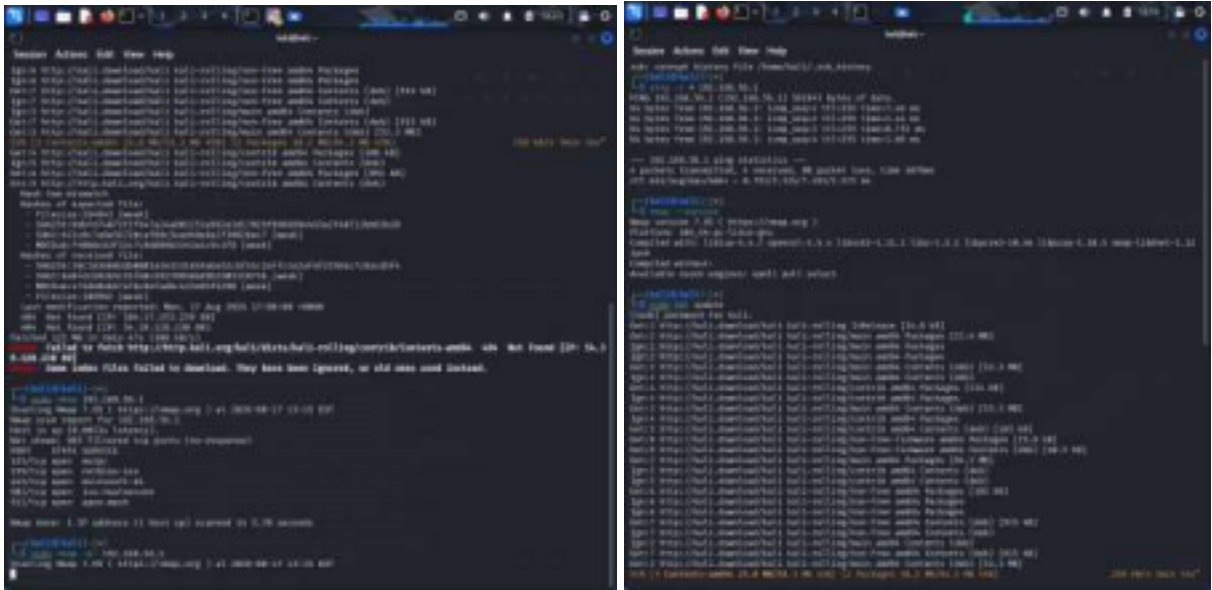
- Disable Telnet.
- Use SSH instead of insecure remote-management protocols.
- Restrict SSH access to trusted administrator IP addresses.
- Disable HTTP management and use HTTPS.
- Change default administrative credentials.
- Use strong authentication.
- Disable unnecessary SNMP services.
- Use secure SNMP configurations where SNMP is required.
- Keep gateway firmware updated.
- Apply firewall/ACL restrictions.
- Monitor management login attempts.
- Separate management traffic from normal user traffic.

- Disable unused services and interfaces.

## Conclusion

The gateway is a critical network infrastructure component. Unnecessary management services can significantly increase the risk of unauthorized access. Nmap enumeration helps administrators identify these exposed services so they can be disabled or appropriately restricted.

Report:



### Code of Conduct:

*I G NITHYA SREE certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.*

**Signature of the student:**

## RUBRICS FOR CALCULATION

| Criteria                 | Weightage (%) | Level 4 (Exemplary)                                                        | Level 3 (Proficient)                     | Level 2 (Developing)                       | Level 1 (Beginning)                 | Mark |
|--------------------------|---------------|----------------------------------------------------------------------------|------------------------------------------|--------------------------------------------|-------------------------------------|------|
| Conceptual Understanding | 20%           | Demonstrates strong understanding of underlying concepts in the simulation | Shows good understanding with minor gaps | Partial understanding; some misconceptions | Lacks understanding of key concepts |      |
| Model Design             | 25%           | Develops accurate, well structured simulation/model independently          | Develops correct model with minor errors | Model is incomplete or requires guidance   | Unable to develop a proper model    |      |

|                     |     |                                                                             |                                             |                                              |                                         |  |
|---------------------|-----|-----------------------------------------------------------------------------|---------------------------------------------|----------------------------------------------|-----------------------------------------|--|
| Tool Usage          | 20% | Uses simulation tools effectively with correct setup and execution          | Uses tools with minor errors or guidance    | Limited ability to use tools properly        | Unable to use simulation tools          |  |
| Analysis of Results | 20% | Provides clear, logical analysis and meaningful interpretation of results   | Analysis is reasonable with minor gaps      | Superficial analysis; limited interpretation | Unable to analyze or interpret results  |  |
| Documentation       | 15% | Presents results clearly with proper documentation and structured reporting | Documentation is adequate with minor issues | Poorly organized or incomplete documentation | No proper documentation or presentation |  |